

# Operating Manual

v3

## Construction Payment Governance Platform

Updated 2026-04-24 · Confidential

---

### CORE GUARANTEES

- ✓ 10-condition server-side release gate — no UI bypass
- ✓ AI draw review precondition with multi-provider fallback chain
- ✓ Hash-chained, append-only audit log with DB-level tamper protection
- ✓ Deal freeze on contract void with admin-only unfreeze (AAL2)
- ✓ Hourly reconciliation with Stripe — Slack + email alerting
- ✓ SLA escalation for unresolved critical issues (> 1 hour)

# TABLE OF CONTENTS

|                                         |           |
|-----------------------------------------|-----------|
| <b>What is Vektrum?</b>                 | <b>2</b>  |
| <b>Tech Stack</b>                       | <b>2</b>  |
| <b>Setup Instructions</b>               | <b>3</b>  |
| <b>System Architecture</b>              | <b>4</b>  |
| Role separation                         | 4         |
| Deal state machine                      | 4         |
| The 10-condition release gate           | 5         |
| AI precondition & provider chain        | 5         |
| Contract enforcement (DocuSign)         | 6         |
| Deal freeze on void                     | 6         |
| Audit log                               | 7         |
| Ops Dashboard                           | 7         |
| <b>Security model</b>                   | <b>8</b>  |
| <b>Reconciliation engine</b>            | <b>9</b>  |
| Detection passes                        | 9         |
| Lookback window                         | 9         |
| Issue severities & auto-fix             | 10        |
| <b>Operational alerting</b>             | <b>10</b> |
| Slack alerting                          | 10        |
| Admin email alerting                    | 11        |
| <b>Cron job — hourly reconciliation</b> | <b>11</b> |
| Phase 1 — Stuck-run detection           | 11        |
| Phase 2 — Reconciliation passes         | 12        |
| Phase 3 — New-findings alerting         | 12        |
| Phase 4 — SLA escalation                | 12        |
| <b>Key API routes</b>                   | <b>13</b> |
| <b>Environment variables</b>            | <b>13</b> |
| <b>Database migrations</b>              | <b>14</b> |
| <b>Deployment</b>                       | <b>14</b> |
| <b>Changelog</b>                        | <b>15</b> |

# WHAT IS VEKTRUM?

The construction industry loses billions annually to payment disputes, draw fraud, and frozen funds. In a typical legacy scenario, a funder wires the full project amount to a contractor at deal start — when a dispute arises over one milestone, the entire capital freezes, halting work site-wide.

Vektrum replaces bulk upfront transfers with milestone-conditional escrow: capital is held by Stripe at deal creation, and each tranche releases only after passing a 10-condition server-side release gate plus an AI precondition. Every action is written to a hash-chained, append-only audit log that cannot be modified or deleted.

## Core Guarantees

| GUARANTEE                            | MECHANISM                                           |
|--------------------------------------|-----------------------------------------------------|
| No release without all 10 conditions | runReleaseGate() — no UI bypass possible            |
| No release without AI draw review    | checkAiPrecondition runs before the gate            |
| No double-release                    | Condition 6 (idempotency guard)                     |
| No release on a voided contract      | Deal freeze on void + gate hard-blocks frozen deals |
| No admin override without MFA        | AAL2 check on every admin write endpoint            |
| No audit manipulation                | Hash-chained log + deny_audit_modification trigger  |

# TECH STACK

| LAYER            | TECHNOLOGY                                                     |
|------------------|----------------------------------------------------------------|
| Framework        | Next.js 15 (App Router, React Server Components)               |
| Database + Auth  | Supabase (Postgres 15, Row-Level Security, SSR auth)           |
| Payments         | Stripe Connect (direct contractor payouts)                     |
| Contract signing | DocuSign (envelope lifecycle via webhook)                      |
| Styling          | Tailwind CSS (dark fintech design system)                      |
| Language         | TypeScript (strict mode throughout)                            |
| AI               | Perplexity sonar-pro → claude-sonnet → gpt-4o (fallback chain) |

# SETUP INSTRUCTIONS

## 1. Clone and install

```
git clone [your-repo-url]
cd vektrum
npm install
```

## 2. Supabase setup

1. Create a project at [supabase.com](https://supabase.com)
2. Run all migration files in order via SQL Editor or Supabase CLI (`supabase/migrations/`)
3. Copy credentials from Settings > API: Project URL, Anon key, Service role key

## 3. Stripe setup

1. Create an account at [stripe.com](https://stripe.com) and enable Connect
2. Copy secret key from Developers > API keys → `STRIPE_SECRET_KEY`
3. Create a webhook endpoint at `https://your-domain.com/api/webhooks/stripe`
4. Subscribe: `account.updated`, `payment_intent.succeeded`, `transfer.created`, `transfer.failed`, `transfer.reversed`
5. Copy webhook signing secret → `STRIPE_WEBHOOK_SECRET`

## 4. DocuSign setup

1. Create a developer account at [developers.docusign.com](https://developers.docusign.com)
2. Create an app; note Integration Key and Account ID
3. Generate RSA keypair; store private key as `DOCUSIGN_PRIVATE_KEY`
4. Configure Connect webhook at `https://your-domain.com/api/webhooks/docusign`
5. Subscribe: `recipient-completed`, `envelope-completed`, `envelope-voided`, `envelope-declined`

## 5. AI providers

Draw review uses a three-provider fallback chain. Set all three for full redundancy:

```
PERPLEXITY_API_KEY=plx-...
ANTHROPIC_API_KEY=sk-ant-...
OPENAI_API_KEY=sk-...
```

See `docs/ai-downtime-plan.md` for full failure-mode documentation.

## 6. Environment variables

```
# Supabase
NEXT_PUBLIC_SUPABASE_URL=https://xxxx.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=eyJhbGci...
SUPABASE_SERVICE_ROLE_KEY=eyJhbGci...

# Stripe
STRIPE_SECRET_KEY=sk_test_...
STRIPE_WEBHOOK_SECRET=whsec_...

# DocuSign
DOCUSIGN_ACCOUNT_ID=...
DOCUSIGN_INTEGRATION_KEY=...
DOCUSIGN_PRIVATE_KEY=...

# AI providers
PERPLEXITY_API_KEY=pplx-...
ANTHROPIC_API_KEY=sk-ant-...
OPENAI_API_KEY=sk-...

# App
NEXT_PUBLIC_APP_URL=http://localhost:3000

# Cron auth
CRON_SECRET=...

# Ops alerting (new in v3)
SLACK_WEBHOOK_URL=https://hooks.slack.com/services/...
EMAIL_FROM=Vektrum <noreply@vektrum.io>
ADMIN_EMAIL=ops@vektrum.io,cto@vektrum.io
RESEND_API_KEY=re_...

# Reconciliation (new in v3)
RECONCILIATION_LOOKBACK_HOURS=72      # default: 72

# Optional
AI_ADMIN_OVERRIDE_TTL_HOURS=4
```

## 7. Run locally

```
npm run dev
```

Open <http://localhost:3000>

# SYSTEM ARCHITECTURE

## Role Separation

| ROLE       | CAPABILITIES                                                                           |
|------------|----------------------------------------------------------------------------------------|
| Contractor | Create deals, add milestones, upload contract, submit draw requests                    |
| Funder     | Fund deals, approve/reject milestones, trigger releases                                |
| Admin      | Read all deals + audit logs; AI overrides (AAL2); unfreeze deals (AAL2); Ops Dashboard |

Admins cannot release funds directly. Release is always triggered by the deal funder. Admin write actions require AAL2 MFA.

## Deal State Machine

```
Deal states
draft
  ■■■ active          (funder funds the deal)
    ■■■ in_progress   (milestone work begins)
    ■■■ completed     (all milestones released)
    ■■■ disputed      (milestone dispute raised)
    ■ ■■■ active      (dispute resolved)
    ■■■ frozen        (contract voided after ≥1 release)
    ■ ■■■ [prior]     (admin unfreezes)
    ■■■ cancelled
```

## Milestone State Machine

```
Milestone states
not_started
  ■■■ in_progress      (contractor starts work)
    ■■■ ready_for_review (contractor submits draw request)
      ■■■ approved      (funder approves)
      ■ ■■■ released    (funder releases payment)
      ■■■ in_progress   (funder requests changes)
      ■■■ disputed
```

## The 10-Condition Release Gate

src/lib/engine/release-gate.ts — runReleaseGate()

Before the gate runs, checkAiPrecondition() must pass. If the deal is frozen, the gate returns an error immediately without checking any conditions. All 10 conditions are evaluated atomically in a single server call.

| #  | CONDITION                 | WHAT IT CHECKS                                      |
|----|---------------------------|-----------------------------------------------------|
| 1  | Milestone approved        | milestone.status === approved                       |
| 2  | Protection ready          | milestone.protection_status === ready_for_release   |
| 3  | Sufficient funded balance | Escrow balance >= milestone amount                  |
| 4  | Stripe payouts enabled    | contractor.stripe_payouts_enabled === true          |
| 5  | Contractor onboarding     | contractor.onboarding_complete === true             |
| 6  | No existing release       | No non-voided release row for this milestone        |
| 7  | No open change orders     | Zero unresolved change orders on deal               |
| 8  | Signed contract           | A non-voided contract row exists for the deal       |
| 9  | Sequential ordering       | All prior-ordered milestones are in released status |
| 10 | Approved lien waiver      | Conditional lien waiver on file for this milestone  |

## AI Precondition & Multi-Provider Chain

src/lib/engine/release-gate.ts — checkAiPrecondition()

An AI draw review must exist and be valid before the gate runs. A review is valid when:

- risk\_level !== critical
- The review was written less than 48 hours ago

| ORDER | PROVIDER   | MODEL                    |
|-------|------------|--------------------------|
| 1     | Perplexity | sonar-pro                |
| 2     | Anthropic  | claude-sonnet-4-20250514 |
| 3     | OpenAI     | gpt-4o                   |

Malformed AI response → synthetic assessment with risk\_level: critical, score: 0, recommendation: hold. This BLOCKS the release rather than silently passing.

## Contract Enforcement (DocuSign)

src/app/api/webhooks/docuSign/route.ts

| WEBHOOK EVENT       | ACTION                                                                 |
|---------------------|------------------------------------------------------------------------|
| recipient-completed | Early-return (individual signer step, not fully executed)              |
| envelope-completed  | Mark contract status = signed; log contract_signed                     |
| envelope-voided     | Mark contract status = voided; run freezeDealIfReleasesExist()         |
| envelope-declined   | Mark contract status = voided with decliner metadata; run freeze check |

## Deal Freeze on Void

When freezeDealIfReleasesExist() fires on envelope-voided or envelope-declined:

1. Checks for any milestone with status = released on the deal.
2. If found — captures deal.status as frozen\_from\_status, sets deal.status = frozen and deal\_freeze\_on\_void = true.
3. Writes an admin\_audit\_log entry: contract\_voided\_with\_releases.

Unfreeze endpoint: POST /api/admin/deals/:dealId/unfreeze

- Requires: admin role + AAL2 MFA + justification (>= 20 chars)
- Returns 409 if the deal is not frozen
- Dual-writes admin\_unfreeze\_deal to the admin audit log

Audit Log

audit\_log table — append-only, hash-chained. Each entry contains: entity\_type, entity\_id, action, actor\_id, created\_at, metadata JSON, previous\_hash, entry\_hash.

A deny\_audit\_modification DB trigger fires RAISE EXCEPTION SQLSTATE 23001 on any UPDATE or DELETE. There is no application-level path to modify audit entries.

Admin Audit Log

admin\_audit\_log table — separate from the operational log; covers privileged write actions only.

| ACTION                        | TRIGGER                                    |
|-------------------------------|--------------------------------------------|
| ai_review_admin_override      | Admin overrides AI precondition            |
| admin_unfreeze_deal           | Admin unfreezes a frozen deal              |
| contract_voided_with_releases | DocuSign void fires with existing releases |
| release_gate_override         | Admin overrides a gate condition (future)  |

Entries without reviewed\_by are flagged as unreviewed in the Ops Dashboard — four-eyes review required.

Ops Dashboard

/dashboard/admin/ops — admin-only, read-only monitoring.

| PANEL           | WHAT IT SURFACES                                               |
|-----------------|----------------------------------------------------------------|
| Summary strip   | Stuck approvals, failed payouts, webhook health, open disputes |
| Search          | Full-text across deals, users, and Stripe transfers            |
| Alert Feed      | All active operational signals sorted by severity              |
| Release Health  | Milestones stuck in approved > 4h; payout_failed milestones    |
| Webhook Health  | Stale pending transfers; last Stripe webhook timestamp         |
| Admin Audit Log | Last 20 privileged write actions; unreviewed-count badge       |

API routes (/api/admin/ops/\*) require admin role + AAL2 MFA. The page server-component forwards session cookies on its internal loopback fetches.



# SECURITY MODEL

## Authentication Levels

| LEVEL           | DESCRIPTION                                                                                         |
|-----------------|-----------------------------------------------------------------------------------------------------|
| AAL1 (Standard) | Email link or password sign-in. Required for all authenticated routes.                              |
| AAL2 (MFA)      | TOTP second factor. Required for ALL admin write actions. Non-MFA admin sessions rejected with 403. |

## Row Level Security

All tables have RLS enabled. Key policies:

- Deals: visible only to their contractor\_id and funder\_id (plus admin via service role)
- Milestones: visible to deal participants only
- Audit log: readable by deal participants; writable only by service role
- Admin audit log: readable and writable by service role only

## Audit Log Tamper Protection

```
DB trigger — fires on UPDATE and DELETE on audit_log and admin_audit_log
CREATE OR REPLACE FUNCTION deny_audit_modification()
RETURNS TRIGGER AS $$
BEGIN
    RAISE EXCEPTION SQLSTATE '23001'
        USING MESSAGE = 'Audit log entries are immutable.';
END;
$$ LANGUAGE plpgsql;
```

No application-level path, migration, or role can bypass this trigger without dropping it first — which would itself be visible in Supabase's database event log.

## RECONCILIATION ENGINE · NEW IN V3

`src/lib/engine/reconciliation.ts` — `runReconciliation(options)`

Runs five detection passes that compare the Vektrum database against live Stripe data. Issues are deduplicated by a stable `dedup_key` so re-runs update existing open issues rather than inserting duplicates. Upserts preserve the original `created_at`, so only first-detection rows have `created_at`  $\geq$  `runStart`.

### Detection Passes

| PASS | DIRECTION            | ISSUE TYPES DETECTED                                  |
|------|----------------------|-------------------------------------------------------|
| 1    | DB → Stripe          | orphaned_transfer, amount_mismatch, metadata_mismatch |
| 2    | Billing records      | missing_billing_record                                |
| 3    | Stripe → DB          | stripe_transfer_not_found                             |
| 4    | Ledger arithmetic    | ledger_drift, fee_ledger_drift                        |
| 5    | Funding confirmation | funding_phantom_balance, funding_missing_webhook      |

### Lookback Window

Default: 72 hours. Priority order:

1. `windowHours` option passed to `runReconciliation()` directly
2. `RECONCILIATION_LOOKBACK_HOURS` environment variable
3. `windowDays` option (legacy; converted to hours) — fallback default is 7 days

Pass 5 applies the same window to `PaymentIntent` results. Stripe Search does not support date-range filters on metadata queries; results are filtered by `pi.created` after fetching.

### Issue Severities

| SEVERITY | ISSUE TYPES                                                                           | AUTO-FIXABLE                          |
|----------|---------------------------------------------------------------------------------------|---------------------------------------|
| critical | orphaned_transfer, missing_stripe_id, amount_mismatch, ledger_drift, funding_ph...    | ledger_drift only                     |
| high     | stripe_transfer_not_found, missing_billing_record, fee_ledger_drift, funding_missi... | missing_billing_record, fee_ledger... |
| medium   | metadata_mismatch                                                                     | No                                    |

Auto-fixable issues can be repaired from the Ops Dashboard (admin only). All other types require manual investigation.

## OPERATIONAL ALERTING · NEW IN V3

### Slack Alerting (`src/lib/engine/alerts.ts`)

Structured Slack messages via Incoming Webhook — Block Kit + colour-coded attachments sidebar:

| SEVERITY | SIDEBAR COLOUR | BATCHING                                                |
|----------|----------------|---------------------------------------------------------|
| critical | #EF4444 red    | None — sent on every occurrence                         |
| warning  | #F59E0B amber  | Slack: every occurrence. Email: 1/hour/type (see below) |

Each message: severity header with emoji, description, metadata fields, dashboard deep-link button.

Transport: exponential backoff — 3 attempts at 1s → 2s → 4s. Never throws. No-ops if SLACK\_WEBHOOK\_URL is unset.

### Admin Email Alerting ([src/lib/engine/notifications.ts](#) — `sendAdminAlert`)

Sends HTML ops-alert emails to all ADMIN\_EMAIL recipients via Resend:

- Critical: always sent immediately — no deduplication
- Warning: module-level Map<string, number> tracks last-sent timestamp per batchKey. At most one warning email per type per hour per process.
- batchKey defaults to the alert title; set it explicitly (e.g. funding\_phantom\_balance) to batch by issue type rather than per-entity message.

## CRON JOB — HOURLY RECONCILIATION · NEW IN V3

/api/cron/reconcile — vercel.json schedule: 0 \* \* \* \* (every hour on the hour)

Sub-daily cron frequency requires the Vercel Pro plan. Each invocation runs four phases in sequence.

### 1 Stuck-Run Detection

- › Query reconciliation\_runs: status = running AND created\_at < NOW() - 2 hours
- › For each stuck run: update status → failed with error\_message
- › Fire CRITICAL Slack + email alert: "Stuck reconciliation run detected"

### 2 Reconciliation Passes

- › Read RECONCILIATION\_LOOKBACK\_HOURS from env (default 72)
- › Call runReconciliation({ windowHours }) — runs all 5 detection passes
- › Window applied to DB queries (Passes 1-4) and PI results (Pass 5)

### 3 New-Findings Alerting

- › Query: run\_id = currentRunId AND created\_at >= runStart AND severity IN (critical, high)
- › created\_at >= runStart identifies FIRST detection — upserts preserve original created\_at
- › Fire per-issue Slack + email alert. Warning emails batched by issue\_type (1/hr/type).

### 4 SLA Escalation

- › Query: severity = critical AND status IN (open, acknowledged) AND created\_at < NOW() - 1 h
- › For each overdue issue: fire CRITICAL alert "UNRESOLVED CRITICAL: [type] for [entity]"
- › Each issue has its own batchKey (sla\_escalation:<issue\_id>) — escalates every run until re

## SLA Escalation Format

UNRESOLVED CRITICAL: [issue\_type] for [deal\_id or entity]

Example:

UNRESOLVED CRITICAL: funding\_phantom\_balance for deal\_abc123

# KEY API ROUTES

| ROUTE                                        | METHOD   | AUTH         | PURPOSE                         |
|----------------------------------------------|----------|--------------|---------------------------------|
| /api/webhooks/stripe                         | POST     | Stripe sig   | Stripe event ingestion          |
| /api/webhooks/docuSign                       | POST     | DocuSign sig | DocuSign envelope events        |
| /api/ai/draw-review                          | POST     | Auth user    | Request AI draw review          |
| /api/admin/ops/alerts                        | GET      | Admin + AAL2 | Aggregated ops alert feed       |
| /api/admin/ops/release-health                | GET      | Admin + AAL2 | Stuck releases + failed payouts |
| /api/admin/ops/webhook-health                | GET      | Admin + AAL2 | Stripe webhook pipeline health  |
| /api/admin/ops/search                        | GET      | Admin + AAL2 | Full-text ops search            |
| /api/admin/milestones/:id/override-ai-review | POST     | Admin + AAL2 | Emergency AI override           |
| /api/admin/deals/:id/unfreeze                | POST     | Admin + AAL2 | Unfreeze contract-voided deal   |
| /api/cron/reconcile                          | GET/POST | CRON_SECRET  | Hourly reconciliation cron      |

# ENVIRONMENT VARIABLES

## Deployment Checklist

|                                 |                                                 |
|---------------------------------|-------------------------------------------------|
| ● NEXT_PUBLIC_SUPABASE_URL      | Supabase project URL                            |
| ● NEXT_PUBLIC_SUPABASE_ANON_KEY | Supabase anon key                               |
| ● SUPABASE_SERVICE_ROLE_KEY     | Supabase service role key                       |
| ● STRIPE_SECRET_KEY             | Stripe secret key                               |
| ● STRIPE_WEBHOOK_SECRET         | Stripe webhook signing secret                   |
| ● DOCUSIGN_ACCOUNT_ID           | DocuSign account identifier                     |
| ● DOCUSIGN_INTEGRATION_KEY      | DocuSign app integration key                    |
| ● DOCUSIGN_USER_ID              | DocuSign user GUID                              |
| ● DOCUSIGN_PRIVATE_KEY          | DocuSign RSA private key                        |
| ● DOCUSIGN_WEBHOOK_SECRET       | DocuSign Connect HMAC secret                    |
| ● PERPLEXITY_API_KEY            | Draw review — primary AI provider               |
| ● ANTHROPIC_API_KEY             | Draw review fallback (provider 2)               |
| ● OPENAI_API_KEY                | Draw review fallback (provider 3)               |
| ● NEXT_PUBLIC_APP_URL           | Production domain — used in emails + deep-links |
| ● CRON_SECRET                   | Vercel cron authentication token                |
| ● RESEND_API_KEY                | Email delivery for ops alerts                   |
| ● ADMIN_EMAIL                   | Comma-separated ops alert recipients            |
| ● SLACK_WEBHOOK_URL             | Slack Incoming Webhook for real-time alerts     |
| ● RECONCILIATION_LOOKBACK_HOURS | Lookback window in hours (default 72)           |
| ● AI_ADMIN_OVERRIDE_TTL_HOURS   | AI override TTL in hours (default 4)            |

● Required

● Recommended

● Optional

## DATABASE MIGRATIONS

All migrations live in `supabase/migrations/` and must be run in filename order.

| MIGRATION FILE                         | WHAT IT ADDS                                                          |
|----------------------------------------|-----------------------------------------------------------------------|
| 20260424000010_contract_uniqueness.sql | Partial unique index on active contracts; deal_freeze_on_void, fro... |

```
# Local reset (applies all migrations)
supabase db reset

# Incremental local push
supabase db push

# Production push
supabase db push --db-url postgresql://postgres:[pw]@db.[ref].supabase.co:5432/postgres
```

## DEPLOYMENT

### Vercel (recommended)

1. Push your repo to GitHub
2. Import the project at [vercel.com/new](https://vercel.com/new)
3. Add ALL environment variables from the reference above in the Vercel dashboard
4. Deploy
5. After deployment: update webhook endpoint URLs in Stripe and DocuSign dashboards to your production domain

The hourly reconciliation cron (0 \* \* \* \*) requires a Vercel Pro plan. On Hobby, change the schedule to 0 2 \* \* \* (daily) and note reduced visibility into financial drift.

# CHANGELOG

| VERSION | DATE       | SUMMARY                                                                                                       |
|---------|------------|---------------------------------------------------------------------------------------------------------------|
| v3      | 2026-04-24 | Reconciliation hardening: hourly cron, alerts.ts (Slack Block Kit + backoff), sendAdminAlert (warning batc... |
| v2      | 2026-04-24 | 10-condition gate; AI multi-provider chain; DocuSign webhook + contract enforcement; deal freeze on voi...    |
| v1      | (initial)  | 4-condition release gate; basic Stripe Connect; simple audit log                                              |